Политика безопасности базы данных

1. Общие положения

Цель данного документа — описать правила доступа пользователей к базе данных task_management.

База данных используется для хранения информации о пользователях, проектах и задачах.

Для защиты данных применяются роли и права доступа.

Роль — это набор разрешений для пользователя. Права доступа определяют, какие действия можно выполнять с данными.

2. Модель управления доступом

Для базы данных используется модель RBAC — ролевое управление доступом.

В этой модели права назначаются ролям, а пользователи получают нужные роли.

Данная модель удобна тем, что каждому сотруднику не нужно отдельно настраивать все разрешения.

3. Описание ролей

В системе были созданы пять ролей:

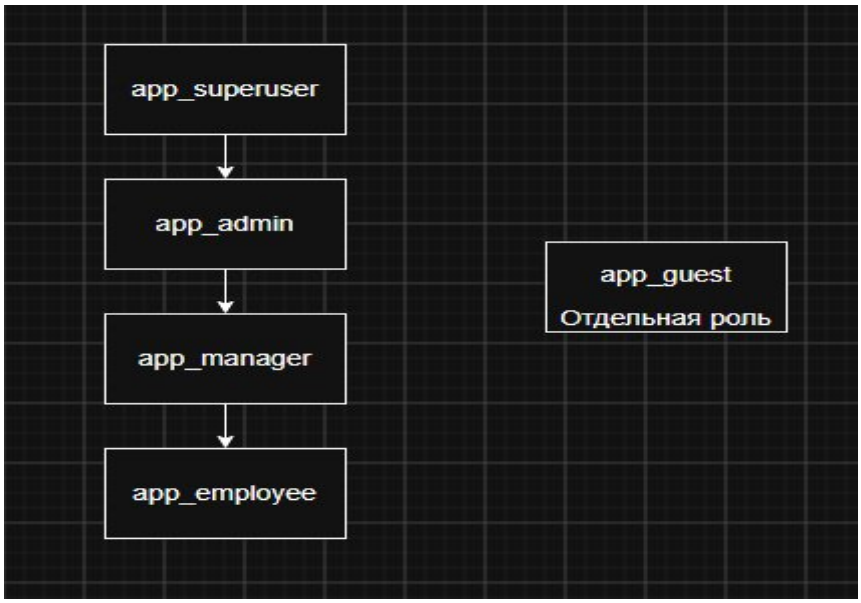
- **app_guest** — гость. Может просматривать проекты.
- **app_employee** — сотрудник. Может просматривать проекты и задачи, создавать задачи и комментарии.
- **app_manager** — менеджер. Имеет права сотрудника, а также может управлять проектами и задачами.
- **app_admin** — администратор. Может управлять данными и создавать таблицы в схеме app.
- **app_superuser** — роль с расширенными правами. Наследует права администратора и имеет дополнительные права на базу данных.

4. Иерархия ролей

В системе используется наследование прав.

Менеджер наследует права сотрудника, администратор — права менеджера, а роль app_superuser — права администратора.

Роль гостя находится отдельно, потому что ей не нужны права сотрудника.



5. Матрица доступа

Для ролей были настроены разные права доступа к таблицам базы данных.

Основные права представлены в таблице.

Действие	**guest**	**employee**	**manager**	**admin**	**superuser**
Просмотр проектов	Да	Да	Да	Да	Да
Просмотр задач	Нет	Свои и общие	Все	Все	Все
Создание задач	Нет	Свои и общие	Да	Да	Да
Изменение задач	Нет	Нет	Да	Да	Да
Удаление задач	Нет	Нет	Да	Да	Да
Просмотр паролей	Нет	Нет	Нет	Да	Да
Просмотр журнала доступа	Нет	Нет	Нет	Да	Да
Создание таблиц в схеме app	Нет	Нет	Нет	Да	Да

Данная таблица показывает основные разрешения, настроенные для каждой роли.

6. Политики RLS

Для дополнительной защиты были настроены политики RLS.

RLS позволяет ограничивать доступ к отдельным строкам таблиц.

Для сотрудников настроен просмотр своих и общих задач. Менеджерам разрешён более широкий доступ.

Также настроена защита таблицы пользователей.

После включения RLS была проведена проверка от имени Bob. Он смог увидеть только задачи, которые ему разрешены.

7. Процедуры управления доступом

Для управления доступом используются команды GRANT и REVOKE.

GRANT позволяет выдавать права пользователям и ролям.

REVOKE позволяет отзывать ранее выданные права.

Администратор должен следить за назначенными правами и проверять, чтобы пользователи не получали лишние разрешения.

Для хранения сведений о действиях предусмотрена таблица access_logs. Автоматическое заполнение журнала в этой работе не настраивалось.

8. Приложения

В ходе практической работы были подготовлены SQL-команды создания таблиц, ролей и настройки прав доступа.

Также было проведено тестирование пользователей Bob, Alice, Diana и Eve.

Результаты проверок и скриншоты представлены в отчёте по практической работе №2. SQL-код сохранён в отдельном файле практика 2.sql.